K. Dhanush
192324087

SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Programme: **B.E / B.Tech**

Course Code: **ITA1439**

Course Name: **Ethical Hacking**

Duration: **1: 30 Hr**

Date: **02-11-2026**

40/50 80%

Max Marks: **50 Marks**

CONTINUOUS INTERNAL ASSESSMENT 1

Course Outcomes
On successful completion of the course, students will be able to:

CO	Course Outcome Statement
CO1	Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.
CO2	Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Answer all the Questions

1. A private bank hires a security firm to test its internet-banking portal before launch. In the same month, a former employee uses old credentials to view customer records, a student runs a downloaded attack tool against the portal "to see what happens", and an activist group defaces the bank's website. Define the term hacker and classify each person or group, including the hired testers, as white hat, black hat, grey hat, script kiddie, hacktivist or insider, with reasons. Explain the ethical principles the testers must follow, such as written authorization, agreed scope, confidentiality, avoiding harm and honest reporting. **(CO1) (BL3)**

2. A student finds an SQL injection flaw in the e-learning portal of another university that exposes the marks and contact details of about 20,000 students, without having permission to test it. The student is considering posting the details on social media, reporting privately to the university, or offering the details in exchange for payment. Analyze the legal position of the student under the Information Technology Act, 2000, with reference to unauthorized access and data theft. Compare full disclosure, responsible (coordinated) disclosure and bug-bounty programmes, and recommend the most appropriate disclosure process and timeline for this case with justification. **(CO1) (BL4)**

3. (a) A college authorizes its security club to carry out a penetration test of the student portal. Before any testing begins, the team must define how the engagement will be conducted. Apply the ethical-hacking methodology by listing its phases — reconnaissance, scanning, gaining access, maintaining access and reporting — and state the objective of each phase. Explain what a written rules-of-engagement / authorization document must specify (in-scope targets, time window, permitted and prohibited techniques, and the point of contact) to keep the engagement lawful, in-scope and non-destructive. **(CO1) (BL3) (5 Marks)**

(b) A security team is authorized to assess the internet exposure of a retail company that uses the domain retailco.example. Explain the difference between passive and active footprinting, and describe how the team would use WHOIS lookups, nslookup or dig, and search-engine operators (site:, filetype:, intitle:) to collect information about the company. For any THREE of these sources, state one item of information it may reveal and the security risk it creates. **(CO2) (BL3) (5 Marks)**

4. During an authorized assessment, a tester runs "dig axfr example.com @ns1.example.com" and the name server returns the full zone, including www (A, 203.0.113.10), vpn (A, 203.0.113.25), hr-portal (A, 10.10.5.20), dev-db (A, 10.10.8.15), mail (MX, priority 10) and a TXT record listing the SPF mail servers. Explain how a DNS zone transfer works and why it is meant only between primary and secondary name servers. Analyze what an attacker could learn from each record to plan further attacks, and recommend countermeasures such as restricting transfers, TSIG authentication and split-horizon DNS. **(CO2) (BL4)**

5. An organization receives an e-mail that appears to come from its IT help desk, asking employees to "verify" their passwords through a link. Later, a caller claiming to be from the help desk asks the accounts section for a one-time password, and a visitor without an ID card follows an employee through a secured door. Identify each attack type (phishing, vishing, pretexting or tailgating) and the psychological principles used, such as authority and urgency. Describe how an authorized social engineering assessment of this organization should be planned, and propose technical, procedural and awareness-based countermeasures. **(CO2) (BL3)**

NAME : K Dhanush Reddy
REG NO : 19332467
CODE : ITA1439

Hacker :- A Hacker is a person who uses computer knowledge and technical skills to identify, access, or modify computer systems and networks. Hackers may work for security improvment illegal activities.

Types of Hackers

* White Hat Hacker :- The security firm hired by the bank in a white hat hacker because it has the permission to test the internet banking portal.

* Black Hat Hacker :- The people who illegelly access system steal information, or damage website are consired, black hat hackers.

* Grey Hat Hacker :- A grey hat hacker finds security of weaknesses without permissions but may not have harmfull intentions

* Insider :- The formor employee is an insider because the previously worked in the bank and are misuing old login credientials to access customer record

* script kiddle :- The script kiddle student is a script kiddle because they uses a download hacking tool without fully understanding how it works.

* Hackivist :- The Hackivist activity group is a hacking because it attacks and defaces the bank websites to express.

Ethical principle's for security Testers :-

* Honest Reporting :- The honest reporting clearly report all discovered vulnerabilities and provide actions
* Written Authorization :- Obtain official written permission before starting security testing
* Agreed Scope :- test only the systems and applications mentioned in the agreement.
* Confidentiality :- keep customer information and sensitivity data private
* Avoiding Harm :- Do not damage systems, delete files, or interrupts banking services.
* The ethical hackers must follow the legal rules and regulations professional responsibilities to protect the organization systems and data.

* Responsible (coordinated) Disclosure :-

* The researcher privately informs the affected Organization

* The organization get time to fix the problem

* The organization programme :-

→ Bug Bounty

* Organizations invites security researches to find the vulnerabilities.

3. a. Ethical Hacking methodology

Ethical hacking follows a step-by-step process to identify security weakness in a system.

* Reconnaissance :-

→ To collect the basic information about the target system

→ Identify domain names, ip addresses, employees and technologies.

* scanning :-

* scan the target network to identify open ports and services

* To Helps identify entry points.

Legal position under the information Technology Act, 2000

The student discovers an SQL injection vulnerability in another universities portal without the permission Accessing or extracting student information without authorizing can create the legal problems

Relevant sections :

* section 43 : covers the unauthorized access, downloading coping, or extracting data from a computer system.

* section 66 : If acts covered under section 43 are commited dishonestly or fraudulently, they may attract

* section 72 : Deals with breach of confidentiality and privacy by a person who obtains access under power provided by the Act.

Types of vulnerabilities Disclousure

* Full Disclousre :

→ The vulnerabilities details are publicly shared immediately

→ it helps users understand the security problem

* Maintaing Access :

* check whether access could be mainted after the entering the system

* perform only approved and controlled tests

Rules of Engagement / Authorization Document

* In scope targets :- Clearly mention which websites servers and IP addresses can be tested

* prohibited techniques :- To clearly identify the restricted activities.

(b.) passive Footprinting :-

passive footprinting means collecting information about a target without directly interacting with its systems

Examples :-

* Searching company websites
* checking public records
* using search engines
* collections publicly available information.

Active footprinting :-

Active fortprinting is the main of directly interaction.

Examples :

* DNS queries
* WHOIS lookups
* Network scanning
* Checking server responses.

Tools used for Foot printing

* WHOIS Lookup :
* provide domain registration information
* may reveal domain owner details, registrar and name servers.

(4.) Definition of DNS Zone Transfer

DNS zone transfer is processes used to copy the DNS records from a primary DNS server to a secondary DNS server.

DNS Zone Transfer works

* The primary DNS server stores the original DNS records
* The secondary server updates the DNS information

Countmeasures :-

1. Restrict Zone Transfer :- Allow zone transfer only to trusted secondary DNS servers.

* Regular monitoring :- Monitor DNS requests and identify unusual zone transfer attempts.

(5.) Social Engineering :-

Social Engineering is a technique in which attackers manipulate people in the main of revailing confidient information or performing actions security.

Types of Attacks :-

* Phishing (Fake email) :- An Attacker sends an email pretending to form the IT help desk.

* vishing (voice phishing) :- An Attacker makes ce phone cal pretening to be an IT help desk employee

psychologies principles used

* Authority :- Attackers pretend to be manager gain thru

* Trust :- Attackers pretend to be familier or authorized

* curiosity :- Fake links and cattractive messages

* Urgency : They create pressure by saying immediate action is required

* Fear : Attackers pretend to be a familiar security problems.

Planning an Authorized Social Engineering

* Obtain written permission from the orginization

* Identify the employee or departments included in the assessment.

Technical countermeasures :-

* use Spam filters and email security systems

* use anti-phishing protection.